GLOBAL CLOUD SERVICES - IT SECURITY & COMPLIANCE STANDARD (SOC2 / ISO 27001)

1. Access Control and Least Privilege Principle
Access to production database infrastructure and pgvector clusters requires hardware security keys (FIDO2) and just-in-time (JIT) role elevation via Okta. All credentials must be rotated at minimum every 90 days. Root-level access to cloud containers is strictly prohibited in customer-facing production VPCs.

2. Encryption Standards
Data at rest must be encrypted using AES-256 with AWS KMS or HashiCorp Vault managed keys.
All data in transit must utilize TLS 1.3 with cipher suites enforcing forward secrecy.
Database backups are automatically encrypted and retained for 30 rolling calendar days.

3. Vulnerability Management and Penetration Testing
Static application security testing (SAST) and container vulnerability scanning run on every Git commit. Third-party penetration tests are commissioned semi-annually. Critical vulnerabilities (CVSS > 9.0) must be remediated or mitigated within 48 hours of public disclosure.